Policy 24 – Vendor & Third-Party Risk

1. Table of Contents

1 Document Content Page

2 Policy Objectives and Scope

2.1 Purpose

2.2 Scope

2.3 Vendor Inventory & Tiering

2.4 Security Due Diligence

2.5 Contractual Safeguards

2.6 Ongoing Monitoring

2.7 Off-boarding & Data Return

3 Policy Compliance

3.1 Compliance Measurement

3.2 Exceptions

3.3 Non-Compliance

3.4 Continual Improvement

2. Policy Objectives and Scope

2.1 Purpose – Manage risks from suppliers that access company data or impact operations.

2.2 Scope – All SaaS, cloud, consulting, and data-processing vendors.

2.3 Vendor Inventory & Tiering

- Maintain central list of active vendors with owner and contact.
- Tier vendors by risk (High = handles customer or Restricted data; Medium = internal tools; Low = no data access).

2.4 Security Due Diligence

- High-risk: obtain SOC 2/ISO 27001 report or complete security questionnaire before contract.

- Medium-risk: basic questionnaire or public security statement review.
- Record findings and approval decision.

2.5 Contractual Safeguards

- Include confidentiality, breach-notification, right-to-audit, and data-return clauses.
- For personal-data processors, execute a data-processing agreement.

2.6 Ongoing Monitoring

- Review High-risk vendors' attestations or questionnaires annually.
- Track security-breach news; initiate assessment if incident reported.

2.7 Off-boarding & Data Return

- On contract end, ensure vendor deletes or returns data; obtain written confirmation.
- Remove integrations and access tokens within 48 h.

3. Policy Compliance

3.1 Compliance Measurement – 100 % High-risk vendors have up-to-date due-diligence evidence; inventory reconciled quarterly.

3.2 Exceptions – Urgent onboarding without full diligence allowed only with executive sign-off and action plan.

3.3 Non-Compliance – Missing evidence or expired contracts flagged to procurement and Security for immediate action.

3.4 Continual Improvement – Streamline questionnaire, add automation, and refine tiering criteria annually.